

Área de Conocimiento de Tecnología de la Información y Comunicación**Auditoria de Sistemas**

Resumen de Tesis de Auditoria de Seguridad Informática con COBIT 4.1 Tesis UNAN

	Elaborado por:	Docente:
Br. Gerson Antonio Valdivia	Br. Stephanie Lucía Mora Chávez	Msc. Leonel Antonio Martínez Zuniga
Br. Haxell Antonio Trejos Rodríguez	Br. Arleth del Rosario Velásquez Gómez	
Br. Alison Michelle Navarro Goussen		

03 de junio, 2026
Managua, Nicaragua

Resumen de Auditoría de Seguridad Informática – MS-América Central (2010)

1. Objetivo y Alcance

Se implementó un modelo de auditoría basado en **COBIT 4.1** para evaluar la seguridad informática del área de TI de MS-América Central durante el año 2010. El alcance comprendió:

- Dirección y planificación de TI.
- Políticas, normas y procedimientos de seguridad.
- Seguridad de los recursos de TI (aplicaciones, información, infraestructura y personas).
- Gestión del outsourcing tecnológico.
- Evaluación y administración de riesgos informáticos.

2. Metodología

La auditoría se desarrolló en tres fases: **Planeación, Examen y Evaluación y Dictamen**. Se aplicaron entrevistas, cuestionarios, listas de verificación, análisis documental y herramientas técnicas como **Nessus 4.4** (escaneo de vulnerabilidades) y revisión de antivirus Symantec, firewall SonicWall y configuración de red. Cada objetivo de control de COBIT se evaluó usando su modelo de madurez y métricas.

3. Hallazgos Críticos por Área

A. Dirección y Organización de TI

- Inexistencia de un plan estratégico y de infraestructura **tecnológica** documentado (PO3, ME1 en nivel 0-2).
- Roles y responsabilidades definidos, pero sin vigilancia formal de los controles de seguridad (PO4).
- No se realizan revisiones independientes del desempeño ni auditorías internas de TI.

B. Políticas y Normas de Seguridad

- Las políticas de seguridad se comunican solo verbalmente; no existe un documento formal que contemple sanciones por incumplimiento (PO6, nivel 2).
- Falta de un marco de control interno de TI documentado y difundido.

C. Seguridad de los Recursos de TI

- **Control de acceso lógico:** definido pero no documentado. Las cuentas y contraseñas no siguen una política estricta de cambio y terceros (proveedor de mantenimiento) conocen credenciales, lo que incrementa el riesgo (DS5, nivel 2).

- **Respaldos:** se realizan semanalmente, pero solo existe una copia dentro de las mismas instalaciones, sin almacenamiento externo (DS11, nivel 3).
- **Protección antivirus:** Symantec Antivirus presente, pero no se actualiza en todos los equipos; se detectaron virus en algunos. No se emiten reportes de incidentes desde el servidor.
- **Capacitación:** no hay programas formales de entrenamiento en seguridad informática para usuarios (DS7, nivel 1).
- **Seguridad física:** adecuada (cámaras, guardias, extintores), aunque faltan detectores de humo y rotulación de medidas de seguridad (DS12, nivel 5).
- **Infraestructura de red:** se detectaron 4 vulnerabilidades de severidad media y 27 bajas mediante escaneo con Nessus (ej. SSL débil, XSS genérico).

D. Outsourcing

- Con **AMNET** (internet) existe un contrato formal con acuerdos de nivel de servicio (SLA) y confidencialidad.
- Con **SEQUINSA** (mantenimiento de equipos) no hay contrato formal, lo que expone a la organización a riesgos de confidencialidad y dependencia (DS2, nivel 3 en documentación, pero incumplimiento en monitoreo).
- No se monitorea el desempeño de los proveedores hasta que ocurre una falla.

E. Riesgo Informático

- No existe un plan de contingencia formal, ni matriz de riesgos documentada. Los incidentes se manejan de manera reactiva e intuitiva (PO9, nivel 1).
- No se registran ni clasifican los incidentes de seguridad, lo que impide el aprendizaje y la mejora continua (DS10).

4. Nivel de Madurez General

El análisis global de los 34 procesos de COBIT evaluados situó a la organización en un **nivel de madurez “Moderado”** (79%), con dominios desiguales:

- **Entregar y Dar Soporte (DS): 86%** – más alto por la robustez en ambiente físico y operaciones.
- **Monitorear y Evaluar (ME): 78%** – carencias en medición de desempeño y revisiones independientes.
- **Planear y Organizar (PO): 80%** – debilidad en planeación estratégica y gestión de riesgos.

- **Adquirir e Implementar (AI): 73%** – falta de manuales de usuario y entrenamiento.

La mayoría de los procesos se encuentran en niveles **1 (Inicial)** o **2 (Repetible)**, indicando acciones informales y dependientes del individuo.

5. Conclusiones Principales

1. La dirección de TI carece de un **plan estratégico y de infraestructura** formal, lo que impide alinear la tecnología con los objetivos del negocio.
2. La **documentación es la debilidad transversal**: políticas, procedimientos de acceso, manuales de usuario, planes de contingencia y registros de incidentes no existen o son informales.
3. La seguridad lógica está implementada técnicamente pero **sin respaldo normativo ni monitoreo continuo**, generando vulnerabilidades explotables.
4. El outsourcing presenta un **riesgo crítico** al no tener contrato con el proveedor de mantenimiento, exponiendo datos sensibles.
5. La **gestión de riesgos es prácticamente inexistente**: no hay análisis formal, matriz de riesgos ni plan de continuidad, dejando a la organización expuesta a pérdidas económicas y de información.
6. Se confirma la hipótesis: una gerencia que no evalúa continuamente sus controles incrementa el riesgo sobre los activos.

6. Recomendaciones Clave

- **Formalizar** un plan estratégico de TI y un plan de infraestructura tecnológica.
- **Documentar** todas las políticas de seguridad, incluyendo sanciones, y difundirlas formalmente.
- **Implementar** un procedimiento estricto de gestión de cuentas y contraseñas, y eliminar el acceso de terceros no controlado.
- **Establecer un contrato formal** con SEQUINSA que incluya cláusulas de confidencialidad y nivel de servicio.
- **Crear un plan de contingencia y continuidad**, con respaldos externos y pruebas periódicas.
- **Realizar auditorías internas periódicas** y adoptar un modelo de monitoreo continuo con indicadores de desempeño.
- **Capacitar** a todos los usuarios en seguridad informática y concientizar sobre riesgos.